



Kali VPN Vulnerability Scanner

Manual de Usuario

Plataforma web para gestión de clientes, conexión VPN y escaneo de vulnerabilidades en redes internas desde un servidor Kali Linux en AWS.

Versión	1.0
Fecha	Marzo 2026
Autor	Datacom Security
Servidor	18.117.130.45 (AWS us-east-2)
Puerto	8040

Contenido

1.	Introducción y Arquitectura	3
2.	Requisitos e Instalación	3
3.	Acceso a la Interfaz Web	4
4.	Gestión de Clientes	4
5.	Conexión VPN	5
6.	Escaneo de Vulnerabilidades	6
6.1	Configurar el escaneo	6
6.2	Perfiles disponibles	7
6.3	Lectura de resultados	8
7.	Exportar Reportes	9
8.	Historial de Escaneos	9
9.	Gestión del Servicio	10
10.	Seguridad y Buenas Prácticas	10

1. Introducción y Arquitectura

El **Kali VPN Vulnerability Scanner** es una plataforma web desplegada sobre un servidor Kali Linux en Amazon AWS que permite realizar escaneos de vulnerabilidades en redes internas de clientes. La herramienta gestiona la conexión VPN al entorno del cliente y ejecuta herramientas como **nmap**, **vulners** y **nikto** directamente desde el servidor Kali, permitiendo operar como si se estuviera físicamente dentro de la red objetivo.

Flujo de trabajo:

Capa	Componente	Descripción
1 — Acceso	Navegador web	El usuario accede a http://18.117.130.45:8040 desde cualquier dispositivo
2 — Plataforma	Flask (Kali AWS)	Servidor web Python que gestiona clientes, VPN y escaneos
3 — Túnel VPN	OpenVPN / WireGuard	El Kali se conecta a la red interna del cliente
4 — Escaneo	nmap · nikto · vulners	Las herramientas analizan la red desde dentro del perímetro

Infraestructura AWS:

Parámetro	Valor
Instancia AWS	i-0149996bf2a11dbdd
Tipo de instancia	t3.micro — us-east-2
IP Pública	18.117.130.45
Sistema Operativo	Kali Linux 2025.4 amd64
Puerto de la aplicación	8040 (TCP)
Servicio systemd	vuln-scanner

2. Requisitos e Instalación

La aplicación ya está desplegada y configurada en el servidor Kali. No se requiere instalación adicional para usar la interfaz web.

Requisitos del usuario (cliente):

- Navegador web moderno: Chrome, Firefox, Edge o Safari
- Acceso a internet o red con visibilidad a 18.117.130.45:8040
- Archivo de configuración VPN del cliente (.ovpn o .conf de WireGuard)
- Credenciales VPN del cliente (si aplica)

Herramientas disponibles en el servidor:

Herramienta	Versión	Uso principal
nmap	7.x+	Escaneo de puertos, detección de SO y versiones

Herramienta	Versión	Uso principal
nmap NSE (vuln)	Incluida	Scripts de vulnerabilidades integrados
vulners	Incluida	Correlación con base de datos de CVEs
nikto	2.x+	Escaneo de vulnerabilidades en servidores web
ssllscan	2.x+	Análisis de configuración SSL/TLS
OpenVPN	2.x+	Conexión VPN con archivos .ovpn
WireGuard	Incluido	Conexión VPN con archivos .conf

■ Si necesitas redespargar la aplicación, ejecuta `./deploy.sh` desde la carpeta local del proyecto con el archivo `kali-aws.pem` disponible.

3. Acceso a la Interfaz Web

Abre tu navegador web e ingresa la siguiente URL:

```
http://18.117.130.45:8040
```

La interfaz cargará automáticamente. No requiere login — asegúrate de que el acceso al puerto 8040 esté restringido a IPs autorizadas en el Security Group de AWS.

Secciones de la interfaz:

Elemento	Ubicación	Función
Sidebar — Clientes	Panel izquierdo	Lista de clientes registrados y formulario de alta
Badge VPN	Header superior derecho	Indica el estado de la VPN y permite conectar/desconectar
Pestaña Escaneo	Área principal	Configuración y ejecución de escaneos en tiempo real
Pestaña Historial	Área principal	Lista de todos los escaneos realizados con opción de exportar
Barra de estado	Pie de página	Estado actual del sistema y duración del escaneo activo

4. Gestión de Clientes

Antes de realizar cualquier escaneo, debes registrar el cliente. Cada cliente almacena su configuración VPN y la red interna objetivo.

Crear un nuevo cliente:

1. En el panel izquierdo, haz clic en el botón **+ Nuevo**.
2. Completa el campo **Nombre / Empresa** (obligatorio).
3. Ingresa la **Red interna en formato CIDR** (ej: 192.168.10.0/24). Este valor se usará automáticamente como objetivo de escaneo.
4. Agrega una descripción opcional para identificar el engagement.
5. Selecciona el **Tipo VPN**: OpenVPN o WireGuard.
6. Sube el archivo de configuración VPN (.ovpn para OpenVPN, .conf para WireGuard) usando el botón **Seleccionar**.
7. Si la VPN requiere autenticación, ingresa **Usuario** y **Contraseña VPN**.
8. Haz clic en **Guardar**. El cliente aparecerá en la lista izquierda.

Editar un cliente existente:

Haz clic en cualquier cliente de la lista izquierda para cargar sus datos en el formulario. Modifica los campos necesarios y haz clic en **Guardar**.

Eliminar un cliente:

Pasa el cursor sobre el cliente en la lista — aparecerá el botón **X** a la derecha. Haz clic para eliminarlo (se pedirá confirmación).

■ Los datos de clientes se almacenan en `/opt/scanner/clients.json` en el servidor Kali. Los archivos VPN se guardan en `/opt/scanner/vpn_configs/`.

5. Conexión VPN

La VPN conecta el servidor Kali a la red interna del cliente, permitiendo que los escaneos se realicen desde dentro del perímetro de red como si fuera un equipo interno. Es el paso más importante antes de escanear redes privadas.

Conectar a la VPN de un cliente:

1. Haz clic en el **badge VPN** en la esquina superior derecha (aparece como '● VPN Inactiva' en rojo).
2. En el modal que se abre, selecciona el **cliente** del dropdown.
3. Haz clic en **Conectar VPN**.
4. El sistema subirá la configuración al Kali y lanzará OpenVPN/WireGuard en segundo plano. El proceso puede tardar entre 10 y 40 segundos.
5. Cuando la VPN esté activa, el badge cambiará a **verde** mostrando el nombre del cliente y la IP asignada en el túnel (ej: tun0: 10.8.0.2/24).
6. Cierra el modal — ya puedes escanear la red interna.

Desconectar la VPN:

Abre el modal VPN (badge superior) y haz clic en **Desconectar**. Siempre desconecta la VPN al finalizar el engagement para liberar recursos.

Estados del badge VPN:

Estado	Color	Significado
● VPN Inactiva	Rojo	No hay túnel VPN activo. No se pueden escanear redes internas.
● VPN: [Cliente]	Verde	Túnel VPN activo. El Kali está conectado a la red del cliente.
Conectando VPN...	Naranja	El proceso de conexión está en curso (10-40 segundos).

■ Solo puede haber una VPN activa a la vez. Para cambiar de cliente, desconecta la VPN actual antes de conectar a otro cliente.

6. Escaneo de Vulnerabilidades

6.1 Configurar el escaneo

En la pestaña **Escaneo**, configura los siguientes parámetros:

Campo	Descripción	Ejemplo
Cliente	Dropdown para seleccionar el cliente activo. Al seleccionarlo, se rellena automáticamente el campo Objetivo.	Empresa ABC
Objetivo	IP, rango CIDR o hostname a escanear. Puede ser un host individual o toda una subred.	192.168.10.0/24 server.local
Perfil de escaneo	Tipo de análisis a realizar. Determina las herramientas y flags utilizados.	OS+ Versiones
Comando (editable)	El comando exacto que se ejecutará. Puedes modificarlo manualmente para ajustar parámetros.	sudo nmap -sS -sV -sC -p1-65535 -T4 192.168.10.0/24

Una vez configurado, haz clic en **■ Iniciar Escaneo**. Los resultados aparecen en tiempo real en el terminal inferior.

6.2 Perfiles de escaneo disponibles

Selecciona el perfil según el objetivo del análisis. Los perfiles más completos toman más tiempo pero detectan más vulnerabilidades.

Perfil	Comando base	Tiempo est.	Uso recomendado
Descubrimiento (hosts vivos)	<code>nmap -sn</code>	1-2 min	Primera fase: identificar qué hosts están activos en la red.
Puertos top-1000	<code>nmap -sS -T4 --open</code>	2-5 min	Escaneo rápido de los 1000 puertos más comunes.
Puertos completos (1-65535)	<code>nmap -sS -T4 -p-</code>	15-30 min	Escaneo exhaustivo. Detecta servicios en puertos no estándar.
Versiones + SO	<code>nmap -sS -sV -O -T4</code>	5-10 min	Identifica versiones de servicios y sistema operativo.
Vulnerabilidades NSE	<code>nmap --script vuln</code>	10-20 min	Detecta CVEs conocidos usando los scripts integrados de nmap.
Vuln + SO + Versiones (Completo)	<code>nmap -sS -sV -O --script vuln</code>	20-40 min	Análisis completo recomendado para auditorías formales.
CVEs con CVSS (vulners)	<code>nmap --script vulners --script-args mincvss=5.0</code>	15-25 min	CVEs con puntuación CVSS ≥ 5.0 usando base de datos vulners.
Web / HTTP (nikto)	<code>nikto -h</code>	5-15 min	Detecta vulnerabilidades en servidores web (XSS, SQLi, misc).
SMB vulnerabilidades	<code>nmap -p445 --script smb-vuln*</code>	2-5 min	EternalBlue, MS17-010 y otros exploits sobre SMB (Windows).
SSL/TLS (ssllscan)	<code>ssllscan</code>	1-3 min	Analiza protocolos débiles, cifrados inseguros y expiración de certificados.

6.3 Lectura de resultados

El terminal muestra la salida en tiempo real coloreada por severidad. El panel derecho **Hallazgos** filtra automáticamente las líneas con severidad CRITICAL, HIGH y MEDIUM.

Severidad	Descripción	Ejemplos típicos
CRITICAL	Vulnerabilidad crítica explotable de forma remota sin autenticación.	EternalBlue, Shellshock, RCE sin auth
HIGH	Vulnerabilidad con CVE conocido o vector de ataque documentado.	CVE con CVSS alto, SQLi, LFI/RFI confirmado
MEDIUM	Configuración débil o servicio con riesgo moderado.	SSL/TLS débil, cipher deprecated, warnings
LOW	Información de baja criticidad o fuga de datos mínima.	Info leak, puertos abiertos conocidos
INFO	Información general del escaneo sin implicación de riesgo.	Hosts activos, puertos, versiones detectadas

7. Exportar Reportes

Una vez finalizado el escaneo, puedes exportar los resultados en tres formatos usando los botones de la barra de herramientas:

Formato	Descripción	Uso recomendado
TXT	Salida completa del escaneo en texto plano con cabecera de metadatos (cliente, objetivo, perfil, fecha).	Exportación técnica o para uso interno.
JSON	Resultados estructurados en JSON con todos los metadatos del escaneo (cliente, objetivo, perfil, fecha).	Integración con otras herramientas de análisis.
HTML	Reporte visual con tabla coloreada por severidad, listo para abrir en navegador.	Presentación a clientes o usuarios no técnicos.

Los reportes también quedan guardados automáticamente en el servidor en `/opt/scanner/scans/` con el formato: `scan_[objetivo]_[id].txt`

Exportar desde el Historial:

En la pestaña **Historial**, cada fila tiene botones **TXT** y **HTML** para descargar el reporte de cualquier escaneo pasado, incluso de sesiones anteriores.

8. Historial de Escaneos

La pestaña **Historial** muestra todos los escaneos realizados en la sesión actual. Para cada escaneo se muestra:

- ID único del escaneo
- Cliente asociado
- Objetivo escaneado
- Perfil utilizado
- Fecha y hora de inicio
- Estado (En curso / Completado)

Acciones disponibles por escaneo:

Botón	Acción
Ver	Reproduce el output del escaneo en el terminal de la pestaña Escaneo.
TXT	Descarga el reporte en formato texto plano.
HTML	Descarga el reporte visual con colores de severidad.

■ El historial persiste durante la sesión del servidor. Si el servicio se reinicia, el historial en memoria se limpia (los reportes guardados en disco permanecen en `/opt/scanner/scans/`).

9. Gestión del Servicio

La aplicación corre como servicio systemd (**vuln-scanner**) en el servidor Kali. Se inicia automáticamente con el sistema. Para gestionarlo via SSH:

Acción	Comando SSH
Ver estado del servicio	<code>ssh -i kali-aws.pem kali@18.117.130.45 'sudo systemctl status vuln-scanner'</code>
Ver logs en tiempo real	<code>ssh -i kali-aws.pem kali@18.117.130.45 'sudo journalctl -u vuln-scanner -f'</code>
Reiniciar el servicio	<code>ssh -i kali-aws.pem kali@18.117.130.45 'sudo systemctl restart vuln-scanner'</code>
Detener el servicio	<code>ssh -i kali-aws.pem kali@18.117.130.45 'sudo systemctl stop vuln-scanner'</code>
Redesplegar la aplicación	<code>cd ~/Documents/Kali && ./deploy.sh</code>

10. Seguridad y Buenas Prácticas

■ Restringir el puerto 8040

En el Security Group de AWS, limita el acceso al puerto 8040 únicamente a las IPs de los consultores autorizados. Evita exponer la interfaz a 0.0.0.0/0.

■ Proteger el archivo .pem

Nunca compartas ni subas el archivo kali-aws.pem a repositorios. Mantén permisos 600 (chmod 600 kali-aws.pem).

■ Desconectar VPN al finalizar

Siempre desconecta la VPN del cliente al terminar el engagement para evitar acceso no autorizado a redes privadas.

■ Documentar autorización

Antes de escanear cualquier red, verifica que cuentas con autorización escrita del cliente. Guarda el contrato o carta de autorización.

■ Limitar el alcance

Usa el campo Objetivo para especificar exactamente los hosts o rangos autorizados. Nunca escanees fuera del alcance definido.

■ Revisar logs regularmente

Revisa los logs del servicio periódicamente para detectar usos no autorizados: `journalctl -u vuln-scanner --since today`.

■ Mantener el servidor actualizado

Ejecuta `sudo apt update && sudo apt upgrade` regularmente en el servidor Kali para mantener las herramientas de escaneo actualizadas.